

**HORTIFRUTI
REVOLUÇÃO**

Auditoria técnica, funcional, visual e operacional — Hortifruti Revolução

Diagnóstico técnico, funcional, visual e operacional

Versão 1.0 • 21 de agosto de 2026

Documento controlado • HRX Solutions • Hortifruti Revolução

Cliente: Hortifruti Revolução

Projeto: Plataforma comercial e operacional

Categoria: Auditoria / Qualidade / Segurança

Versão: 1.0

Data: 21/08/2026

Branch auditada: agent/auditoria-homologacao-final-20260821

Produção: Render, branch main, deploy manual

Destino documental: HRX SOLUTIONS → Central de Documentos → Hortifruti Revolução → Auditorias

PENDÊNCIA DE PUBLICAÇÃO: este arquivo está preparado e classificado para a Central de Documentos da HRX. A gravação automática não foi executada porque o Hortifruti não possui integração de escrita com a Central HRX neste repositório.

A. Resumo executivo

O sistema possui uma arquitetura consistente e controles de segurança acima da média para o estágio atual: Next.js 16, APIs server-side, Neon Auth, Postgres com RLS, isolamento cliente/admin, histórico operacional, snapshots de preços, PWA com atualização controlada e 110 testes de regressão aprovados na validação final.

A produção publicada no Render respondeu corretamente, protegeu rotas e APIs autenticadas e apresentou boa qualidade visual nas superfícies públicas desktop e mobile. A branch de auditoria amplia a experiência administrativa desktop, endurece Web Push, entrega, fornecedores, espelho fiscal e acessibilidade mobile.

O sistema, contudo, **não está pronto para operação comercial real**. O banco padrão contém dados identificados como QA (QA-E2E-*), não há usuário cliente vinculado, fornecedores, emitente fiscal ou piloto homologado. Os cinco pedidos existentes estão em compra sem transações de compra. Assim, catálogo, preço personalizado, pedido, consolidação, entrega, notificação ao cliente e fechamento fiscal não puderam ser aprovados como ciclo real ponta a ponta.

Maturidade estimada: 72%. A base de código e os controles são sólidos; impedem 100%: dados reais não carregados, ausência de usuário cliente, fornecedores e emitente fiscal, migration fiscal da branch ainda não aplicada, PWA sem ícone 512 íntegro, falta de teste efetivo de Web Push em dispositivo e ausência de homologação operacional completa.

B. Resultado por área

Área	Resultado	Síntese
Mobile	⚠️ Aprovado com ressalvas	Superfícies públicas sem overflow em 320 px; alvo de toque corrigido na branch. Fluxos autenticados bloqueados por ausência de usuário cliente.
Desktop Web	⚠️ Aprovado com ressalvas	Site público aprovado; branch amplia dashboard administrativo. Administração real depende de sessão e dados operacionais válidos.
PWA	❌ Reprovado	Manifest, SW e atualização existem; falta ícone 512 e o PNG 192 possui CRC inválido para validadores. Instalação/recebimento real não homologados.
Fluxo operacional	🚫 Bloqueado	Não há clientes vinculados, fornecedores, transações de compra, separação, entrega ou piloto homologado.
Banco de clientes	⚠️ Aprovado com ressalvas	Modelagem PF/PJ, fiscal, timestamps e RLS presentes; apenas um cadastro de QA e zero vínculos de cliente.

Banco de valores	⚠️ Aprovado com ressalvas	Preço geral e específico, precisão e snapshot no pedido estão implementados; seis preços personalizados sem vigência.
Interface	✅ Aprovado	Identidade consistente, premium e responsiva nas superfícies observáveis.
Usabilidade	⚠️ Aprovado com ressalvas	Boa hierarquia; alvos públicos mobile corrigidos. Fluxo interno integral não pôde ser percorrido.
Documentação	⚠️ Aprovado com ressalvas	README e arquitetura são úteis; relatório preparado, publicação na Central pendente.
Manual	✅ Aprovado	Manual operacional V1 criado e destinado à Central HRX.
Simulações	🚫 Bloqueado	Contratos automatizados passaram; cenários reais A-I dependem de dados, usuários, dispositivos e configuração externa.
Notificações	🚫 Bloqueado	Há 3 subscriptions admin ativas; nenhuma subscription cliente e nenhum recebimento físico confirmado.
Espelho NFS-e	🚫 Bloqueado	O sistema atual trata venda de mercadorias e espelho NF-e. Aplicabilidade de NFS-e precisa de decisão fiscal formal.
Segurança	⚠️ Aprovado com ressalvas	RLS, guards e 401 aprovados. Headers corrigidos na branch; CSP permanece pendente de projeto compatível com Next.

C. Problemas encontrados

AUD-001 — P1 — Dados de QA no banco padrão

Problema: produtos e preços usam SKUs QA-E2E-*; cinco pedidos foram criados no mesmo instante e permanecem em compra.

Impacto: indicadores e testes não representam operação real; risco de confundir homologação com produção.

Causa: carga de QA no branch padrão do Neon.

Evidência: 1 cliente, 6 produtos, 6 preços personalizados, 5 pedidos, 19 itens e 1 lote; todos os pedidos em purchasing.

Correção: não executada por envolver exclusão/alteração destrutiva de dados.

Situação: 🚫 BLOQUEADO — confirmar descarte controlado dos registros QA e fornecer carga real.

AUD-002 — P1 — Ciclo operacional sem dados mínimos

Problema: zero fornecedores, zero transações de compra, zero recebimentos, zero itens separados, zero entregas e nenhum piloto.

Impacto: consolidação, recebimento, rateio, separação e entrega não podem ser homologados na prática.

Causa: implantação real incompleta.

Correção: componentes e contratos existem; falta configuração/dados.

Situação: 🚫 BLOQUEADO — cadastrar fornecedores e homologar um pedido piloto.

AUD-003 — P1 — Web Push sem confirmação ponta a ponta

Problema: existem três subscriptions ativas, todas administrativas; não há usuário cliente vinculado nem evidência de recebimento físico.

Impacto: não é possível afirmar que mudança de status chega ao cliente.

Causa: ausência de conta cliente/dispositivo homologado.

Correção: branch contém hardening de endpoint, retry limitado e desativação de subscriptions expiradas.

Situação: 🚫 BLOQUEADO — dispositivo iOS e Android, conta cliente vinculada e chaves VAPID do Render.

AUD-004 — P2 — Alvos públicos mobile abaixo de 44 px

Problema: botão Entrar, ações do cadastro e link de privacidade mediam entre 15 e 42 px de altura.

Impacto: toque impreciso e menor acessibilidade.

Causa: seletores de acessibilidade não abrangiam botão aninhado; regra posterior reduzia ações do cadastro.

Correção: seletores ampliados e regressão criada.

Reteste: 320×720, login e cadastro, nenhum alvo visível abaixo de 44 px (exceto controle gráfico não interativo do formulário).

Situação: ✅ Corrigido no commit 243d662.

AUD-005 — P1 — Cabeçalhos HTTP de segurança ausentes

Problema: produção não enviava HSTS, nosniff, proteção contra frame, política de referência ou permissões.

Impacto: exposição desnecessária a clickjacking, interpretação incorreta de MIME e recursos sensíveis do navegador.

Causa: next.config.ts sem política global de headers.

Correção: headers globais adicionados e testados localmente.

Situação: ✅ Corrigido no commit 44c5c3f; publicação no Render pendente.

AUD-006 — P1 — Manifest PWA sem asset obrigatório íntegro

Problema: manifest declara apenas 192×192; o PNG versionado apresenta CRC inválido em validadores e não existe 512×512.

Impacto: instalação e splash podem falhar ou variar em Chromium/Android.

Causa: exportação de asset incompleta/corrompida.

Correção: não foi recriada a marca sem asset mestre confiável.

Situação: 🚫 BLOQUEADO — fornecer/exportar PNG oficial íntegro 192×192 e 512×512, incluindo variante maskable segura.

AUD-007 — P2 — Preços personalizados sem vigência

Problema: os seis preços específicos não possuem valid_from nem valid_until.

Impacto: não há janela temporal explícita para prevalência comercial.

Causa: carga QA sem vigência.

Correção: o snapshot do pedido já preserva preço histórico; falta governança do cadastro.

Situação: ⚠️ Pendente de dados e regra comercial.

AUD-008 — P1 — Emitente fiscal e documento oficial não configurados

Problema: zero perfis de emitente e zero relatórios fiscais.

Impacto: pré-faturamento e autorização oficial não podem ser homologados.

Causa: configuração externa ausente.

Correção: branch amplia snapshot fiscal versionado; integração/emissor real ainda é necessário.

Situação: 🚫 BLOQUEADO — dados do emitente, ambiente, certificado/provedor e homologação.

AUD-009 — P2 — Escopo fiscal NF-e versus NFS-e

Problema: o sistema foi modelado para mercadorias (NCM, CEST, CFOP, itens e NF-e), enquanto a solicitação cita NFS-e de serviços.

Impacto: implementar NFS-e sem definição pode gerar documento fiscal conceitualmente incorreto.

Causa: divergência de requisito/aplicabilidade tributária.

Correção: nenhuma emissão foi simulada; a interface deve continuar chamando o artefato de espelho/pré-faturamento até autorização oficial.

Situação: 🛑 BLOQUEADO — validação do contador responsável sobre documento aplicável.

AUD-010 — P2 — CSP não implantada

Problema: não há Content-Security-Policy.

Impacto: defesa em profundidade contra XSS fica incompleta.

Causa: Next.js exige estratégia de nonce/hash compatível com scripts e deploy.

Correção: não aplicada de forma improvisada para evitar quebra do frontend.

Situação: ⚠ Pendente de projeto e homologação específica.

D. Correções realizadas

- Experiência administrativa desktop ampliada (89c6c1b).
- Vínculos de fornecedores ativos endurecidos (4938ed0).
- Cautela em duas vias, A4, marca-d'água, assinaturas e carimbo (b81ec88, 9b31b98, 50b019b).
- Entrega e cadastro Web Push endurecidos (6e44b97, alteração concomitante já presente na branch).
- Espelho fiscal versionado ampliado (1f047e0, alteração concomitante já presente na branch).
- Alvos públicos mobile corrigidos e retestados (243d662).
- Headers HTTP globais adicionados e retestados (44c5c3f).

E. Testes realizados

Ambiente	Resolução	Fluxo	Esperado	Obtido	Status
Produção Render	1440×900	Home pública	Layout desktop próprio, sem overflow	Hierarquia premium e uso horizontal adequado	PASS
Produção Render	1440×900	Login/cadastro	Formulários completos	Renderização e navegação corretas	PASS
Produção Render	320×720	Home/login/cadastro	Sem overflow	Largura ≤ viewport	PASS
Branch local	320×720	Login/cadastro após correção	Alvos ≥44 px	Nenhum alvo acionável abaixo de 44 px	PASS
Produção Render	—	/admin e /cliente sem sessão	Redirecionar para login	Redirecionamento confirmado	PASS
Produção Render	—	APIs privadas sem sessão	HTTP 401	Seis endpoints retornaram 401	PASS
Produção Render	—	Manifest/SW/assets	HTTP 200 e tipos corretos	Manifest e SW corretos; ícone possui problema estrutural	FAIL
Neon padrão	—	Integridade	Sem	Zero órfãos e duplicidades nas	PASS

		referencial	órfãos/duplicidades	verificações	
Neon padrão	—	Ciclo completo	Pedido até fechamento	Dados mínimos ausentes	BLOCKED
Local	—	Regressões automatizadas	Suite verde	110/110 na validação final	PASS
Local	—	Lint	Sem erros	Sem erros; CSS ignorado pelo ESLint conforme configuração	PASS
Local	—	Build Next	Compilar e tipar	Compilação e TypeScript aprovados no baseline	PASS

Simulações A–I

Cenário	Pré-condição	Resultado esperado	Resultado obtido	Status
A — Cliente novo	Cadastro real e aprovação	Cadastro → vínculo → primeiro pedido	Cadastro público disponível; vínculo inexistente	BLOCKED
B — Preço geral	Cliente vinculado + produto	Preço base aplicado no servidor	Contrato e modelagem presentes; sem usuário cliente	BLOCKED
C — Preço individual	Preço vigente por cliente	Específico prevalece sobre geral	Dados específicos existem; vigência ausente; sem usuário	BLOCKED
D — Vários produtos	Catálogo e cliente	Pedido com snapshots e total consistente	19 itens existentes sem inconsistência matemática	PASS com ressalva QA
E — Consolidação	Vários pedidos aprovados	Lote rastreável até itens	1 lote/19 fontes; nenhuma transação real	BLOCKED
F — Status até conclusão	Compra/recebimento/entrega/fiscal	Histórico completo	Pedidos parados em compra	BLOCKED
G — Falha de API	Endpoint indisponível	Erro recuperável, sem falso vazio	Componentes distinguem erro/vazio; não induzida em produção	PASS contratual
H — Mobile/PWA	Dispositivo e instalação	Standalone, atualização e push	UI mobile aprovada; instalação/push físico bloqueados	BLOCKED
I — Admin desktop	Sessão admin	Dashboard e operação densa	Código/branch e dashboard público avaliados; sessão não usada	BLOCKED

F. Pendências

Código

- Projetar CSP com nonce/hash e validar todas as rotas.
- Adicionar asset 512×512 e maskable após receber fonte íntegra.
- Automatizar auditoria real de navegador com contas de homologação não produtivas.

Infraestrutura

- Confirmar workspace Render e consultar deploy/logs/métricas.
- Publicar a branch validada na main e acionar deploy manual.
- Aplicar migration fiscal pendente após ensaio em branch Neon.

Configuração

- Confirmar VAPID no Render.
- Configurar emitente/provedor/certificado fiscal conforme aplicabilidade.
- Definir ambiente de homologação separado do banco padrão.

Dados

- Autorizar limpeza dos registros QA-E2E- *.
- Importar clientes, produtos, preços com vigência e fornecedores reais.
- Vincular ao menos um usuário cliente verificado.
- Selecionar e homologar pedido piloto.

Integração externa

- Confirmar emissor fiscal e documento aplicável (NF-e ou NFS-e).
- Testar consulta CNPJ e IE com dados reais e fontes externas disponíveis.
- Confirmar recebimento Web Push em iOS/Android e navegador convencional.

Informação do cliente

- Tabela de preços oficial e regras de vigência.
- Dados fiscais do emitente e orientação contábil.
- Usuários autorizados e dispositivos de homologação.

G. Documentação criada/atualizada

- AUDITORIA_TECNICA_FUNCIONAL_OPERACIONAL_V01.md — destino: Auditorias.
- MANUAL_DE_USO_HORTIFRUTI_REVOLUCAO_V01.md — destino: Manuais.
- Versões DOCX equivalentes — destino idêntico na Central HRX.

Publicação automática na Central: pendente; os documentos estão preparados, versionados e classificados, sem alegação de armazenamento remoto.